

Ortak Ağ Saldırıları

Ağ Saldırılarına Genel Bakış

- Kötü amaçlı yazılım yüklendiğinde, yük, ağla ilgili çeşitli saldırılara neden olmak için kullanılabilir.
- Saldırıları azaltmak için saldırı türlerini anlamak yararlıdır. Ağ saldırılarını kategorilere ayırarak, bireysel saldırılar yerine saldırı türlerini ele almak mümkündür.
- Ağlar aşağıdaki saldırı türlerine karşı hassastır:
 - Keşif Saldırıları
 - Erişim Saldırıları
 - DoS Saldırıları

Keşif Saldırıları

- Keşif bilgi toplamaktır.
- Tehdit aktörleri, sistemlerin, hizmetlerin veya güvenlik açıklarının yetkisiz olarak keşfedilmesi ve haritalandırılması için keşif saldırıları kullanır. Keşif saldırıları erişim saldırılarından veya DoS saldırılarından önce gelir.

Kötü niyetli tehdit aktörleri tarafından keşif saldırıları yapmak için kullanılan bazı teknikler tabloda açıklanmıştır.

Teknik	Açıklama
Hedef hakkında bilgi toplama	Tehdit oyuncusu, bir hedef hakkında bilgi arıyor. Google araması, kuruluşların web sitesi, whois ve daha fazlası dahil olmak üzere çeşitli araçlar kullanılabilir.
Hedef ağın ping taramasını başlatma	Bilgi sorgusu genellikle hedefin ağ adresini gösterir. Tehdit aktörü artık hangi IP adreslerinin aktif olduğunu belirlemek için bir ping taraması başlatılabilir.
Etkin IP adreslerinin bağlantı noktası taramasını başlatma	Hangi bağlantı noktalarının veya hizmetlerin kullanılabilir olduğunu belirlemek için kullanılır. Bağlantı noktası tarayıcılarına örnek olarak Nmap, SuperScan, Angry IP Scanner ve NetScanTools verilebilir.
Güvenlik açığı tarayıcılarını çalıştırma	Bu, bilgisayarda çalışan uygulama ve işletim sisteminin türünü ve sürümünü belirlemek için tanımlanan bağlantı noktalarını sorgulamaktır. Araç örnekleri Nipper, Core Impact, Nessus, SAINT ve Open VAS'dir.
İstismar araçlarını çalıştırma	Tehdit oyuncusu şimdi sömürülebilecek savunmasız hizmetleri keşfetmeye çalışıyor. Metasploit, Core Impact, Sqlmap, Social Engineer Toolkit ve Netsparker gibi çeşitli güvenlik açığından yararlanma araçları bulunmaktadır.

Eriřim Saldırıları

- Eriřim saldırıları, kimlik doęrulama hizmetleri, FTP hizmetleri ve web hizmetlerindeki bilinen güvenlik açıklarından yararlanır. Bu tür saldırıların amacı, web hesaplarına, gizli veri tabanlarına ve dięer hassas bilgilere girmektir.
- Tehdit aktörleri, veri almak, erişim elde etmek veya erişim ayrıcalıklarını yönetici durumuna yükseltmek için ağ cihazlarındaki ve bilgisayarlardaki erişim saldırılarını kullanır.
- Parola Saldırıları: Parola saldırısına, tehdit aktörü çeşitli yöntemler kullanarak kritik sistem parolalarını bulmaya çalışır. Parola saldırıları çok yaygındır ve çeşitli parola kırma araçları kullanılarak başlatılabilir.
- Kimlik Sahtekarlığı Saldırıları: Kimlik sahtekarlığı saldırılarına, tehdit aktörü aygıtı verileri tahrif ederek başka bir aygıt gibi görünmeye çalışır. Yaygın kimlik sahtekarlığı saldırıları arasında IP kimlik sahtekarlığı, MAC sahtekarlığı ve DHCP sahtekarlığı bulunur. Bu kimlik sahtekarlığı saldırıları ileride daha ayrıntılı olarak ele alınacaktır.
- Dięer erişim saldırıları řunları içerir:
 - Güven istismarları
 - Bağlantı noktası yönlendirmeleri
 - Ortadaki adam saldırıları
 - Arabellek taşması saldırıları

Sosyal Mühendislik Saldırıları

- Sosyal mühendislik, bireyleri eylemleri gerçekleştirmeye veya gizli bilgileri ifşa etmeye yönlendirmeye çalışan bir erişim saldırısıdır. Bazı sosyal mühendislik teknikleri bizzat yapılırken, dięerleri telefonu veya interneti kullanabilir.
- Sosyal mühendisler genellikle insanların yardımcı olma istekliliğine güvenir. Ayrıca insanların zayıf yönlerini de avlarlar. (Aldatma Sanatı, Kevin Mitnick)

Sosyal Mühendislik Saldırıları	Açıklama
Pretexting (Bahane Uydurmak)	Bir tehdit aktörü, alıcının kimliğini doęrulamak için kişisel veya finansal verilere ihtiyaç duyuyormuş gibi yapar.
Phishing (Oltalama)	Tehdit aktörü, alıcıyı cihazlarına kötü amaçlı yazılım yüklemesi için kandırmak veya kişisel veya finansal bilgileri paylaşmak için meşru, güvenilir bir kaynaktan olduęu düşünölen sahte e-postalar gönderir.
Spear Phishing (Mızrak Avı)	Bir tehdit aktörü, belirli bir kişi veya kuruluş için özel olarak hazırlanmış, hedeflenen bir kimlik avı saldırısı oluşturur.
Spam (İstenmeyen E-posta)	İstenmeyen posta olarak da bilinir, bu genellikle zararlı bağlantılar, kötü amaçlı yazılım veya aldatıcı içerikler içeren istenmeyen bir e-postadır.

Something for Something (Bir şey için bir şey)	Bazen “Quid pro quo – her şey karşılıklı” olarak da adlandırılır. Bu bir tehdit aktörünün hediye gibi bir şey karşılığında bir kişiden kişisel bilgi talep etmesidir.
Baiting (Yemleme)	Tehdit oyuncusu, kötü amaçlı yazılım bulaşmış bir flash sürücüyü herkese açık bir konumda bırakır. Bir kurban sürücüyü bulur ve istemeden kötü amaçlı yazılım yükleyerek şüphesiz bir şekilde dizüstü bilgisayarlarına yerleştirir.
Impersonation (Başkasının kimliğine bürünme)	Bu tür bir saldırı, bir tehdit aktörünün bir kurbanın güvenini kazanmak için olmadıkları biri gibi davrandığı saldırıdır.
Tailgating (Arkadan Takip)	Burada bir tehdit aktörü, yetkili bir kişiyi güvenli bir bölgeye erişmek için hızlı bir şekilde peşinden takip eder.
Shoulder Surfing (Omuzdan Bakma)	Burada bir tehdit aktörü, parolalarını veya diğer bilgilerini çalmak için göze çarpan bir şekilde birinin omzunun üzerinden bakar.
Dumpster Diving (Çöp Dalışı)	Burada bir tehdit oyuncusu gizli belgeleri bulmak için çöp kutularını karıştırır.

- Social Engineering Toolkit – Sosyal Mühendislik Araç Seti (SET), beyaz şapkalı korsanların ve diğer ağ güvenliği profesyonellerinin kendi ağlarını test etmek için sosyal mühendislik saldırıları oluşturmalarına yardımcı olmak için tasarlanmıştır.
- İşletmeler, kullanıcılarını sosyal mühendisliğin riskleri konusunda eğitmeli ve kimliklerini telefonla, e-posta veya şahsen doğrulamak için stratejiler geliştirmelidir.

DoS ve DDoS Saldırıları

- Denial of Service (Hizmet Reddi - DoS) saldırısı, kullanıcılara, cihazlara veya uygulamalara bir tür ağ hizmetlerinde kesinti oluşturur. İki ana tip DoS saldırısı vardır:
- Ezici Trafik Miktarı – Tehdit Aktörü, ağın, ana bilgisayarın veya uygulamanın işleyemeyeceği kadar büyük miktarda veri gönderir. Bu, iletim ve yanıt sürelerinin yavaşlamasına neden olur. Ayrıca bir cihazı veya hizmeti de bozabilir.
- Kötü Amaçlı Biçimlendirilmiş Paketler – Tehdit aktörü kötü niyetli olarak biçimlendirilmiş bir paketi bir bilgisayara veya uygulamaya gönderir ve alıcı bunu işleyemez. Bu, alıcı cihazın çok yavaş çalışmasına veya çökmesine neden olur.
- DoS saldırıları büyük bir risktir çünkü iletişimi keser ve önemli ölçüde zaman ve para kaybına neden olurlar. Bu saldırıların vasıfsız bir tehdit oyuncusu tarafından bile yürütülmesi nispeten kolaydır.
- Distributed DoS Attack – Dağıtılmış DoS Saldırısı (DDoS), DoS saldırısına benzer, ancak birden çok koordineli kaynaktan kaynaklanır.